Планировщик отпусков

КОРПОРАТИВНЫЙ ГРАФИК ОТПУСКОВ И СОГЛАСОВАНИЙ

Самооценка информационной безопасности

Матрица прав, OWASP ASVS L1, остаточные риски · версия 1.0.0

30 октября 2026

© Alexander Yurasov

Содержание

1 О документе 3

2 Итог 4

3 Матрица прав 5

4 Найденные недостатки и исправления 6

5 Самооценка по OWASP ASVS 4.0.3, уровень 1 8

5.1 V2. Аутентификация 8

5.2 V3. Управление сеансами 9

5.3 V4. Разграничение доступа 10

5.4 V5. Проверка входных данных и кодирование вывода 11

5.5 V7. Обработка ошибок и журналирование 11

5.6 V8. Защита данных 12

5.7 V9. Защита каналов связи 12

5.8 V10. Вредоносный код 12

5.9 V11. Бизнес-логика 13

5.10 V12. Файлы 13

5.11 V13. API 13

5.12 V14. Конфигурация 14

6 Аудит зависимостей 15

7 Остаточные риски и рекомендации 16

8 Пакет для внешнего теста на проникновение 17

1 О документе

Отчёт самооценки информационной безопасности «Планировщика отпусков» версии 1.0.0 для приёмки службой ИБ (история E50-02). В нём:

- автоматическая проверка матрицы прав — каждая операция API каждой ролью;
- найденные при самооценке недостатки и их исправление;
- самооценка по OWASP ASVS 4.0.3, уровень 1, с доказательствами;
- аудит зависимостей и принятые остаточные риски;
- пакет для внешнего теста на проникновение.

Самооценка не заменяет внешний тест на проникновение и не является сертификацией. Доказательство в отчёте — автоматический тест, который выполняется в CI на каждый push, или место в коде и конфигурации; ручных утверждений без ссылки нет. Сводный чек-лист из 16 требований для приёмки — документ 1, раздел «Чек-лист безопасности»; эксплуатационные меры организации — «Руководство по развёртыванию».

2 Итог

ПОКАЗАТЕЛЬ	ЗНАЧЕНИЕ
Операций API в контракте	83
Проверок матрицы прав	93 случая × 5 ролей (аноним, сотрудник, руководитель, кадровая служба, администратор) = 465; все пройдены
Найдено недостатков при самооценке	14: высокой важности — 2, средней — 3, низкой — 6, процесса и документации — 3
Исправлено в 1.0.0	14 из 14, на каждый — автоматический тест или проверка CI
Требований ASVS L1 оценено	55 строк оценки (требование или группа соседних требований) без неприменимых: выполнено — 44, частично — 9, обеспечивает организация — 2; не применимо — 4
Уязвимости зависимостей	В поставке клиента — 0; в поставке сервера — 5 (3 высокой, 2 средней важности по оценке npm), все в путях, недоступных для входных данных пользователей; приняты как остаточный риск с планом устранения

Вывод. Механизмы аутентификации, управления сеансами и разграничения доступа реализованы на сервере и подтверждены автоматическими тестами. Недостатки, найденные при самооценке, исправлены до выпуска. Остаточные риски относятся к настройке у организации (TLS, MFA через провайдера единого входа, длина пароля 12 символов) и к обновлению зависимостей в следующих версиях.

3 Матрица прав

Тест `server/test/rights-matrix.e2e.test.ts` для каждой операции контракта вызывает её от имени каждой роли и сверяет ответ с ожидаемым:

ОЖИДАНИЕ	ЧТО СЧИТАЕТСЯ ВЫПОЛНЕННЫМ
Доступ	Ответ не `401`, не `403` и не `5xx`: права пройдены; `400`, `404` и `409` — проверки данных после прав
Запрет	Точно `403` (или `404`, где сервер не раскрывает существование чужого объекта)
Аноним	`401`, кроме открытых операций: вход, обновление токена, требования к паролю, настройки единого входа, производственный календарь

Объекты, которые операция меняет (заявка, сотрудник, отдел, замещение), создаются для каждой роли заново — проверка одной роли не влияет на другую. Тест начинается с проверки полноты: каждый `operationId` контракта должен встречаться в матрице, и операция без строки в матрице роняет CI.

Дополнительно проверяется:

- карточка коллеги без служебной роли не содержит логина, почты, норм дней, табельного номера и служебных прав; полная — себе, руководителю, кадровой службе и администратору;
- поиск по табельному номеру доступен только служебным ролям;
- чужое уведомление нельзя пометить прочитанным;
- ранее существовавшие тесты прав по предметным областям: `staff.e2e`, `requests.e2e`, `delegation.e2e`, `notices.e2e`, `planning.e2e`, `security.e2e`.

Матрица прав для людей — документ 2, раздел «Матрица прав»; тест и документ сверены, расхождений нет.

4 Найденные недостатки и исправления

№	НЕДОСТАТОК	ВАЖНОСТЬ	ИСПРАВЛЕНИЕ	ПОДТВЕРЖДЕНИЕ
F-1	В `docker-compose.yml` было значение `JWT_SECRET` по умолчанию, а сервер принимал access-токен без идентификатора сеанса: при запуске без `.env` любой, кто знает значение из репозитория, мог подписать токен любого сотрудника	высокая	Значения по умолчанию нет — compose не запускает стенд без секрета; токен принимается только с идентификатором живого сеанса из БД, поэтому одного секрета для подделки недостаточно	`auth.e2e` («токен с другим алгоритмом подписи, даже тем же секретом, не принимается»: токен без сеанса и с несуществующим сеансом — 401)
F-2	PostgreSQL был опубликован на всех интерфейсах узла с паролем из репозитория	высокая	Порт опубликован только на `127.0.0.1`	`docker-compose.yml`; дымовой прогон CI
F-3	Карточка и список сотрудников отдавали любому вошедшему нормы дней и перенос остатка коллег (баланс по матрице прав закрыт), табельные номера, логины и признаки служебных ролей	средняя	Коллеге без служебной роли — справочная карточка; поиск по табельному номеру — только служебным ролям	`rights-matrix.e2e`
F-4	Обращения за пределы контура: проверка версии Prisma CLI при каждом старте (`checkpoint.prisma.io`), статистика установки пакета `@scarf/scarf` при сборке, проверка новой версии npm при старте через `npx`, значок проверки Swagger UI (`validator.swagger.io`)	средняя	`CHECKPOINT_DISABLE=1`, `SCARF_ANALYTICS=false` и `scarfSettings`, миграции без `npx`, `NPM_CONFIG_UPDATE_NOTIFIER=false`, `validatorUrl: null`	`server/Dockerfile`, `server/src/main.ts`; проверки независимости Н-1…Н-7 «Инструкции для эксперта»
F-5	Неверный старый пароль при смене пароля не считался неудачной попыткой: с похищенным сеансом пароль можно было подбирать без ограничения; ответ `401` заставлял клиент обновлять токен и повторять запрос	средняя	Попытка считается неудачной, после порога — блокировка, как при входе; ответ `400`	`security.e2e` («неверный старый пароль при смене…»)

№	НЕДОСТАТОК	ВАЖНОСТЬ	ИСПРАВЛЕНИЕ	ПОДТВЕРЖДЕНИЕ
F-6	Сотрудник не узнавал о смене или сбросе своего пароля (ASVS 2.2.3)	низкая	Уведомление `password_changed` в интерфейсе и письмом	`security.e2e` («уведомление о смене пароля»)
F-7	Ответы API раскрывали платформу (`X-Powered-By: Express`)	низкая	Заголовок отключён	`security.e2e` («заголовки ответов API»)
F-8	Ответы API с персональными данными могли сохраняться в кэше браузера и прокси (ASVS 8.2.1)	низкая	`Cache-Control: no-store` ; график отпусков — `private, no-cache` со сверкой по ETag	`security.e2e` («заголовки ответов API»)
F-9	Изменение правил организации и его запись в журнал изменений выполнялись разными транзакциями (нарушение ADR-006)	низкая	Одна транзакция	`tz-coverage.e2e` («изменение правил — в журнале изменений со значениями до и после»)
F-10	`refresh_tokens` , очередь писем и уведомления росли без срока хранения	низкая	Ежедневная задача `data-retention` ; документы кадрового учёта и журнал изменений не удаляются	`security.e2e` («сроки хранения служебных данных»)
F-11	nginx ограничивал тело запроса 1 МБ при допустимом файле импорта 2 МБ: ответ `413` вместо понятной ошибки	низкая	`client_max_body_size 3m` для `/api/`	`web/nginx.conf`
F-12	Конвейер CI не запускался на ветке версии `v1.0.0` (фильтр `v0.*`); стенд Gitea развёртывался с секретом по умолчанию	процесс	Фильтр `v*` ; секрет стенда — из секретов репозитория Gitea	прогоны CI ветки `v1.0.0`
F-13	Контракт называл пять операций «только для администратора», хотя код и матрица прав разрешают их кадровой службе	документация	Контракт исправлен, каталог операций документа 2 пересобран	`rights-matrix.e2e` ; задание CI «Документы: таблицы сверены с кодом» (`gen_tables.py --check`)
F-14	Неиспользуемый `RolesGuard` отвечал `401` с кодом запрета	документация	Удалён	—

5 Самооценка по OWASP ASVS 4.0.3, уровень 1

Статусы: **выполнено** — требование выполнено программой и подтверждено; **частично** — выполнено с оговоркой; **организация** — выполняет организация при развёртывании; **н/п** — не применимо (функции нет).

5.1 V2. Аутентификация

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
2.1.1 Длина пароля не меньше 12 символов	частично	Минимальная длина — правило организации от 8 до 64; по умолчанию 8. Для соответствия L1 организация задаёт 12	`password-policy.ts`, `security.e2e`
2.1.2 Пароли до 128 символов	выполнено	Ограничение 128 символов во всех формах	DTO `auth.controller.ts`, `employees.controller.ts`
2.1.3–2.1.4 Без усечения, любые символы Unicode	выполнено	Пароль хешируется целиком, состав символов не ограничивается	`passwords.ts`
2.1.5–2.1.6 Смена пароля с вводом текущего	выполнено	Смена своего пароля требует текущего	`security.e2e`
2.1.7 Проверка по списку распространённых паролей	выполнено	Встроенный список с учётом русской раскладки и транслита	`password-policy.unit`
2.1.8 Индикатор стойкости пароля	частично	Форма показывает требования политики и причину отказа; индикатора стойкости нет	`ChangePasswordView.vue`
2.1.9–2.1.10 Без правил состава и принудительной периодической смены	выполнено	Нет требований к классам символов и срока действия пароля	`password-policy.ts`
2.1.11–2.1.12 Вставка из менеджера паролей, показ пароля	выполнено	Поля не запрещают вставку; кнопка «Показать»	`LoginView.vue`
2.2.1 Защита от подбора	выполнено	Лимит частоты на адрес и логин в PostgreSQL, блокировка после серии ошибок, в том числе при смене пароля	`auth.e2e`, `security.e2e`
2.2.3 Уведомление об изменении данных аутентификации	выполнено	Уведомления о блокировке и о смене или выдаче пароля	`security.e2e`

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
2.3.1 Начальный пароль случайный, одноразовый	выполнено	Сброс генерирует сервер; выданный пароль нужно сменить при первом входе	`security.e2e`, `staff.e2e`
2.4.1 Хранение паролей стойкой функцией с солью	выполнено	scrypt (N = 16384) с 16-байтной солью	`passwords.unit`
2.5.x Восстановление доступа	н/п	Самостоятельного восстановления нет: пароль выдаёт кадровая служба; секретных вопросов нет	—
2.7.x–2.8.x Одноразовые коды	н/п	Не используются; второй фактор — у провайдера единого входа	—

5.2 V3. Управление сеансами

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
3.1.1 Токен сеанса не передаётся в адресе	частично	Access-токен — в заголовке, refresh — в cookie. Поток событий открывается по одноразовому билету в адресе: он действует 60 секунд, имеет отдельную аудиторию JWT и не даёт вызвать другие операции	`events.e2e`
3.2.1–3.2.3 Новый сеанс при входе, энтропия не меньше 64 бит, безопасное хранение	выполнено	Refresh-токен — 32 случайных байта, в БД хранится SHA-256; access-токен — в памяти вкладки	`auth.e2e`
3.3.1 Выход завершает сеанс на сервере	выполнено	Выход отзывает все токены сеанса	`security.e2e`
3.3.2 Повторная аутентификация не реже раза в 30 дней	выполнено	Refresh-токен действует 30 дней	`auth.e2e`
3.4.1–3.4.3 Cookie: `Secure`, `HttpOnly`, `SameSite`	выполнено	`vp_refresh`: `HttpOnly`, `SameSite=Strict`, `Secure` в режиме production	`auth.e2e`

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
3.4.4 Префикс `__Host-`	частично	Cookie ограничена путём `/api/v1/auth`, что несовместимо с `__Host-` (требует `Path=/`); узкий путь и `SameSite=Strict` закрывают ту же угрозу	`auth.controller.ts`
3.4.5 Путь cookie	выполнено	`/api/v1/auth`	`auth.controller.ts`
3.7.1 Повторная проверка перед критичными действиями	выполнено	Смена пароля требует текущего пароля	`security.e2e`

5.3 V4. Разграничение доступа

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
4.1.1 Права проверяются на сервере	выполнено	Каждая операция — в сервисе; служебные роли читаются из БД	`rights-matrix.e2e`
4.1.2 Атрибуты прав не подменить	выполнено	Права не берутся из тела запроса и токена; токен связан с живым сеансом	`rights-matrix.e2e`, `auth.e2e`
4.1.3 Наименьшие привилегии	выполнено	Кадровая служба не меняет учётные записи администраторов и коллег, не выдаёт служебные роли; коллеге — справочная карточка	`staff.e2e`, `rights-matrix.e2e`
4.1.5 Отказ при ошибке	выполнено	Ошибка проверки — `403` или `500` без данных	`contract.e2e`
4.2.1 Защита от доступа к чужим объектам по идентификатору	выполнено	Заявки, извещения, уведомления, группы, сеансы проверяются по владельцу или праву	`rights-matrix.e2e`
4.2.2 Защита от CSRF	выполнено	Изменяющие операции требуют Bearer-токена из памяти вкладки; refresh-cookie — `SameSite=Strict`	`auth.e2e`
4.3.1 Многофакторная аутентификация администраторов	организация	Второй фактор — у провайдера единого входа; `LOCAL_LOGIN=false` оставляет пароль только администраторам для аварийного входа	«Руководство по развёртыванию», «Единый вход»

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
4.3.2 Нет листинга каталогов	выполнено	nginx отдаёт только сборку SPA, листинг выключен	`web/nginx.conf`

5.4 V5. Проверка входных данных и кодирование вывода

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
5.1.1–5.1.4 Проверка входных данных по схеме	выполнено	DTO class-validator с `whitelist`: типы, длины, форматы, перечисления; неизвестные поля отбрасываются	`contract.e2e`, e2e предметных областей
5.2.1–5.2.5 Санитизация, отсутствие `eval` и шаблонов из данных пользователя	выполнено	Пользовательский HTML не принимается и не выводится; `v-html` запрещён правилами разработки	ESLint клиента, AGENTS.md
5.3.1–5.3.3 Контекстное кодирование вывода	выполнено	Интерполяция Vue с автоэкранированием; CSP без inline-скриптов	e2e «CSP стенда не нарушается»
5.3.4 Параметризованные запросы к БД	выполнено	Prisma; сырые запросы — только тегированные шаблоны с параметрами	обзор кода `$queryRaw`
5.3.8 Внедрение команд ОС	н/п	Сервер не вызывает команды ОС	—

5.5 V7. Обработка ошибок и журналирование

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
7.1.1–7.1.2 В журналах нет паролей, токенов и иных секретов	выполнено	Журнал API — маршрут без строки запроса, код, длительность, сотрудник, адрес; запросы к БД — без параметров	`observability.e2e`
7.4.1 Общая ошибка с идентификатором для поддержки	выполнено	problem+json с кодом из каталога и `requestId`; интерфейс показывает «Код запроса»	`observability.e2e`

5.6 V8. Защита данных

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
8.2.1 Запрет кэширования чувствительных ответов	частично	`Cache-Control: no-store` у ответов API; график отпусков — `private, no-cache` со сверкой по ETag (без изменений — `304`): это производительность на 5000 сотрудников, график доступен всем сотрудникам организации	`security.e2e`
8.2.2 Данные не хранятся в хранилище браузера	выполнено	Токен — в памяти вкладки; в `localStorage` только настройки интерфейса: тема, свёрнутое меню, масштаб графика	`web/src/api/client.ts`, `useTheme.ts`
8.3.1 Чувствительные данные — в теле или заголовках, не в адресе	частично	Как 3.1.1: одноразовый билет потока событий в адресе	`events.e2e`

5.7 V9. Защита каналов связи

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
9.1.1–9.1.3 TLS для всех соединений клиента	организация	TLS и HSTS — на обратном прокси организации; cookie сеанса `Secure` в режиме production	«Руководство по развёртыванию», «Настройка»

5.8 V10. Вредоносный код

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
10.3.1 Безопасное обновление	выполнено	Самообновления нет: обновление выполняет администратор организации	«Руководство по развёртыванию», «Обновление»
10.3.2 Целостность сторонних ресурсов	выполнено	Сборка не загружает скрипты, стили и шрифты извне; CSP `script-src 'self'`	`web/nginx.conf`

5.9 V11. Бизнес-логика

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
11.1.1–11.1.2 Шаги процессов по порядку, ограничение частоты	выполнено	Переходы состояний заявки проверяются сервером; гонки — блокировками строк; лимит входа	`requests.e2e`, гонки в e2e
11.1.4 Защита от автоматизации	частично	Лимит частоты — у входа и смены пароля; у прочих операций — нет (внутренняя система, доступ только аутентифицированных сотрудников)	`auth.e2e`

5.10 V12. Файлы

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
12.1.1 Ограничение размера загружаемых файлов	выполнено	Импорт — один файл до 2 МБ; nginx — до 3 МБ	`import.e2e`, `web/nginx.conf`
12.3.x, 12.4.x Пути и хранение файлов	н/п	Загруженный файл разбирается в памяти и не сохраняется	`imports.controller.ts`

5.11 V13. API

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
13.1.1 Единая кодировка	выполнено	JSON UTF-8	`contract.e2e`
13.1.3 В адресах API нет секретов	частично	Как 3.1.1	`events.e2e`
13.2.1 Разрешены только нужные методы	выполнено	Маршруты строго по контракту, остальное — `404`	`contract.e2e`
13.2.2 Проверка схемы JSON	выполнено	DTO по контракту	`contract.e2e`
13.2.3 Защита REST от CSRF	выполнено	Как 4.2.2	`auth.e2e`
13.2.5 Проверка типа содержимого	выполнено	JSON-операции принимают `application/json`, импорт — `multipart/form-data`	`import.e2e`

5.12 V14. Конфигурация

ТРЕБОВАНИЕ	СТАТУС	КАК ВЫПОЛНЕНО	ДОКАЗАТЕЛЬСТВО
14.2.1 Компоненты актуальны, уязвимости отслеживаются	частично	SBOM и лицензионный гейт в CI; `npm audit` — раздел «Аудит зависимостей»	задание CI «SBOM и лицензии»
14.2.2 Лишние функции отключены	выполнено	Служебные адреса `/healthz`, `/readyz`, `/metrics` не проксируются наружу	дымовой прогон CI
14.3.2 Отладочный режим выключен	выполнено	Ответы `500` без стека; стек — только в журнале сервера	`contract.e2e`, `observability.e2e`
14.3.3 Заголовки не раскрывают версии	выполнено	`X-Powered-By` отключён, `server_tokens off` в nginx	`security.e2e`
14.4.1–14.4.7 Заголовки безопасности	выполнено	CSP, `X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`, `Permissions-Policy`, `Content-Type` с кодировкой	`web/nginx.conf`, `app.setup.ts`, e2e CSP
14.5.1–14.5.3 Методы, Origin, CORS	выполнено	CORS не включён: API доступен только с собственного адреса	`app.setup.ts`

6 Аудит зависимостей

`npm audit` 29.10.2026 по рабочим зависимостям (`--omit=dev`) — тем, что входят в поставку:

ПАКЕТ	ВАЖНОСТЬ	ПУТЬ	ЭКСПЛУАТИРУЕМОСТЬ В ПРОГРАММЕ	РЕШЕНИЕ
`deepmerge-ts` < 8 (через `@prisma/config` , `prisma`)	высокая	Утилита миграций Prisma	Переполнение стека при слиянии рекурсивных объектов; утилита сливает только конфигурацию из репозитория при запуске миграций — входные данные пользователей туда не попадают	Остаточный риск; обновление до Prisma 7 — в следующей версии (мажорное обновление ORM)
`uuid` < 11.1.1 (через `exceljs`)	средняя	Выгрузки XLSX	Нет проверки границ буфера в функциях v3/v5/v6 с переданным буфером; exceljs вызывает только v4 без буфера	Остаточный риск; исправление предлагается только откатом exceljs на 3.4.0 — следить за выпуском exceljs

Клиент: 0 уязвимостей в поставке (8 пакетов в сборке). Уязвимости инструментов сборки и тестирования (зависимости разработки) в поставку не входят и устраняются в порядке обновления зависимостей.

Среда выполнения: Node.js 20 вышел из поддержки 30.04.2026 — в версии 1.0.0 образы `server` и сборка клиента переведены на `node:22-alpine` (Node.js 22 LTS, `docs/decisions.md`); сервер проверяется в CI на Node.js 20 и 22.

7 Остаточные риски и рекомендации

РИСК	КТО УСТРАНЯЕТ	РЕКОМЕНДАЦИЯ
Пароль короче 12 символов по умолчанию	Организация	Задать «Минимальная длина пароля» 12 в правилах организации
Нет второго фактора у входа по паролю	Организация	Единый вход через провайдера с MFA и `LOCAL_LOGIN=false`
TLS и HSTS	Организация	Сертификат и перенаправление на HTTPS на обратном прокси
Пароль учётной записи PostgreSQL из `docker-compose.yml`	Организация, разработчик	Порт БД закрыт снаружи (F-2); вынести пароль в `.env` — в следующей версии
Одноразовый билет потока событий в адресе	Принят	Билет живёт 60 секунд и пригоден только для потока событий
Уязвимости `deepmerge-ts` и `uuid`	Разработчик	Обновление Prisma до 7 и exceljs в 1.1.0
Демонстрационные пароли опубликованы в README	Организация	На стенде эксперта и рабочем контуре — свои пароли; демо-данные не загружать в рабочую БД

8 Пакет для внешнего теста на проникновение

ПУНКТ	СОДЕРЖАНИЕ
Объект	«Планировщик отпусков» 1.0.0: веб-интерфейс, API `/api/v1`, поток событий
Стенд	Отдельный стенд с демонстрационными данными по «Инструкции для эксперта»; адрес `[заполняет правообладатель]`; HTTPS на обратном прокси
Учётные записи	По одной на роль: сотрудник, руководитель отдела, кадровая служба, администратор — логины из «Инструкции для эксперта», пароли передаются отдельно `[заполняет правообладатель]`
Документы	Контракт `contracts/openapi-vacation-api-v1.yaml`, документ 2 (матрица прав, каталог ошибок), настоящий отчёт
В границах	Аутентификация и сеансы, разграничение доступа между ролями и между сотрудниками, внедрение в параметры и тела, загрузка файла импорта, выгрузки XLSX, поток событий, заголовки безопасности, раскрытие сведений
Вне границ	Отказ в обслуживании и нагрузочное воздействие (есть отдельные нагрузочные испытания), социальная инженерия, инфраструктура организации (прокси, провайдер единого входа, почтовый сервер), физический доступ
Правила	Работа только на выделенном стенде; данные не выносятся за пределы стенда; найденная критичная уязвимость — сообщение правообладателю в течение суток
Результат	Отчёт с классификацией по CVSS и шагами воспроизведения; повторная проверка исправлений
Контакт	`[заполняет правообладатель]`